

TECNICATURA UNIVERSITARIA EN CIBERSEGURIDAD

INFRAESTRUCTURAS CRITICAS

Trabajo practico integrador

Dante Gabriel Balbuena Atar

Profesor: Damián Giacone

Argentina, Tucumán, Tafí Viejo

Fecha - 10/11/2025

Contenido

Trabajo practico integrador	1
1. INTRODUCCIÓN	2
2. DESARROLLO	2
2.1.3 Inserción del diagrama Purdue	4
2.3 ACCESO REMOTO SEGURO (RD/VPN)	4
2.3.1 Topología propuesta (DMZ-centrica)	4
2.3.2 Reglas de firewall que habilitan RD/VPN (resumen)	5
2.3.3 Controles de seguridad	5
2.3.4 Matriz de acceso por rol	5
2.3.5 Cumplimiento ISA/IEC 62443-3-3	6
2.4 Firewalls y Política de Reglas	6
2.4.1 FW-OT (L3 ↔ L3.5) y FW-Corp (L3.5 ↔ L4/N5)	6
2.4.2 Política Global	6
2.5.1 Plan de Direcccionamiento y Naming	6
2.5.2 Convención de Nombres (Naming Convention)	7
2.6 Telemetría, Logs y Monitoreo	7
2.6.1 Arquitectura de Monitoreo	7
2.6.2 Política de Retención y Auditoría	7
2.6.3 Alertas y Correlación de Eventos	8
2.7 Justificación Técnica y Trade-offs	8
3. CONCLUSIONES	8
4. REFERENCIAS	9

1. Introducción

El presente trabajo tiene como objetivo diseñar la arquitectura de red de la planta potabilizadora *AquaSur*, aplicando el modelo Purdue para segmentar las zonas operativas y corporativas, y garantizar la seguridad en los flujos de información entre ellas. Se desarrollan la zonificación OT/IT, los conductos autorizados, la topología de acceso remoto seguro (RD/VPN), las reglas de firewall, el plan de direccionamiento y la gestión de telemetría y monitoreo.

El diseño propuesto busca cumplir con los principios de **seguridad industrial** **definidos por la norma ISA/IEC 62443**, priorizando la disponibilidad, integridad y trazabilidad de las operaciones críticas.

2. Desarrollo

2. Zonificación y Celdas por Niveles Purdue

La arquitectura de red de la planta de potabilización “AquaSur” se diseñó aplicando el modelo Purdue (ISA-95) y los principios de segmentación definidos por la norma ISA/IEC 62443.

El objetivo de esta zonificación es aislar las funciones de proceso, control, supervisión, operaciones y corporativo, minimizando el riesgo de movimientos laterales, asegurando el principio de mínimo privilegio y garantizando trazabilidad completa entre niveles.

2.1 Tabla principal de zonificación por nivel

Nivel	Zona	Subred	Activos principales	Función	Justificación
N0/N1	Celdas de Proceso (P1–P6)	10.10.10.0/24 → P110.10.11.0/24 → P210.10.12.0/24 → P310.10.13.0/24 → P410.10.14.0/24 → P510.10.15.0/24 → P6	PLC-P1 a PLC-P6, sensores y actuadores	Control local de cada etapa (toma, coagulación, decantación, filtración, cloración, distribución)	Cada celda se aísla en su propia subred L1 para evitar propagación lateral y cumplir ISA/IEC 62443-3-3 SR 3.1 (zonas seguras).
N2	Control y Supervisión (Sala de Control)	10.10.20.0/24	2 HMI, Servidor SCADA, Historiador, Servidor de Ingeniería	Supervisión del proceso, registro histórico y programación de PLCs	Aísla el control lógico del campo; comunicación ascendente vía OPC-UA/Modbus a PLCs. Cumple separación L1/L2 (Purdue).
N3	Operaciones de Sitio	10.10.30.0/24	Servidor ETL/Reportes, usuarios de operaciones, estaciones de análisis de laboratorio	Procesamiento de datos OT, generación de reportes locales	Permite manipular datos sin tocar PLCs; sirve de puente control ↔ DMZ.
N3.5	DMZ Industrial	10.10.40.0/24	Bastion/Jump Server, Relay de Historiador, Servidor de Archivos OT (patches/firmware), Syslog/Forwarder	Frontera segura entre OT y IT; punto único de entrada/salida de datos y accesos remotos	Separa dominios OT/IT, inspecciona todo tráfico, almacena archivos con antivirus y mTLS; cumple ISA/IEC 62443-3-3 SR 5.2 (Defensa en profundidad).

N4/N5	Corporati vo y Cloud	10.10.50.0/24	ERP, BI, SIEM corporativo, Nube de Backups de Reportes	Consumo de informes productivos y análisis de rendimiento	Solo recibe datos de la DMZ vía Relay; sin acceso directo a OT. Cumple principio de mínimo privilegio.
-------	----------------------------	---------------	--	---	--

2.1.1 Detalles por Celda (N0/N1)

Celda	Proceso	Activos	Subred /24	PLC	Ejemplo de nombres
P1	Toma y Bombeo	PLC-P1 + instrumentación de caudal y nivel	10.10.10.0/24	PLC-P1 (10.10.10.100)	PLC-P1.toma.ot.local
P2	Coagulaci ón/Flocula ción	PLC-P2 + sensores de pH y dosificación	10.10.11.0/24	PLC-P2 (10.10.11.100)	PLC-P2.coag.ot.local
P3	Decantaci ón	PLC-P3 + válvulas de purga y nivel	10.10.12.0/24	PLC-P3 (10.10.12.100)	PLC-P3.decant.ot.local
P4	Filtración	PLC-P4 + presostatos y lavado de filtros	10.10.13.0/24	PLC-P4 (10.10.13.100)	PLC-P4.filt.ot.local
P5	Cloración	PLC-P5 + medición de cloro y dosificación	10.10.14.0/24	PLC-P5 (10.10.14.100)	PLC-P5.clor.ot.local
P6	Distribució n	PLC-P6 + bombas de salida a red	10.10.15.0/24	PLC-P6 (10.10.15.100)	PLC-P6.dist.ot.local

2.1.3 Inserción del diagrama Purdue

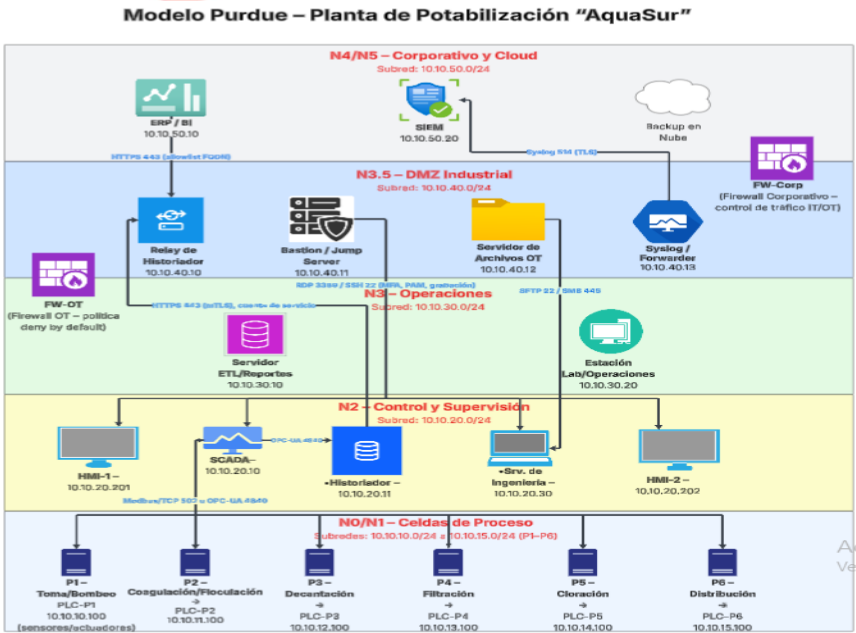


Figura 1. Arquitectura Purdue de la Planta AquaSur
(Diagrama disponible en versión editable en [este enlace](#))

2.2 Conductos Autorizados y Controles

Se definieron los flujos autorizados entre zonas Purdue con sus respectivos **protocolos, puertos, dirección y controles aplicados**, priorizando el principio de **mínimo privilegio** y la segmentación OT/DMZ/IT.

Detalle completo disponible en: [TIF_BalbuenaDante_Tablas.xlsx](#) – Hoja “Conductos”.

2.3 Acceso Remoto Seguro (RD/VPN)

2.3.1 Topología propuesta (DMZ-centrica)

-- Concentrador VPN en DMZ (N3.5).

SSL-VPN o IPsec con split-tunnel deshabilitado (todo el tráfico del cliente se fuerza por DMZ).
Postura de endpoint (AV habilitado, disco cifrado, OS parchado).

-- Bastion / Jump Server (N3.5).

Punto único de salto hacia N2 con:

MFA (TOTP/Push), **PAM** (elevación JIT), **grabación de sesión** (video/keystrokes), **aprobación por ticket**.

Políticas de sesión: time-out, bloqueo de copiar/pegar y redirecciones (unidades/impresoras).

-- Flujo autorizado (sin túneles a OT):

Cliente VPN → Bastion (N3.5) → HMI/SCADA/Ing. (N2) mediante RDP 3389 / SSH 22.

Prohibido: acceso directo a PLCs (N1) o subredes N1/N2 desde el cliente.

-- Consumo de datos por dirección/BI:

Cliente VPN → Relay (N3.5) → BI/ERP (N4/N5) por HTTPS 443 (solo lectura).

No hay salto a hosts de N2.

Secuencia de conexión (resumen).

1. Usuario se autentica en **VPN (DMZ)** con MFA.
2. Accede al **portal del Bastion** y solicita destino permitido (HMI/SCADA/Ing.).
3. **PAM** otorga credenciales temporales; el Bastion **origina** la sesión **RDP/SSH** hacia N2.
4. **FW-OT/FW-Corp** registran y filtran; logs del Bastion y firewalls se envían al **SIEM (N4/N5)**.

Principios aplicados: mínimo privilegio, *deny by default*, trazabilidad, separación de dominios (OT/DMZ/IT).

2.3.2 Reglas de firewall que habilitan RD/VPN (resumen)

- **FW-Corp (N3.5 ↔ N4/N5):**
 - Allow **Cliente** ↔ **Concentrador VPN (N3.5)** (puertos de la VPN).
 - Allow **SIEM (N4)** ← **Bastion/Syslog (N3.5)** Syslog 514/TLS.
 - Deny resto.
- **FW-OT (N3 ↔ N3.5):**
 - Allow **Bastion (N3.5)** → **SCADA/HMI/Ing. (N2)** TCP 3389/22.

- Deny
(Reglas completas en la sección 5.)

resto.

2.3.3 Controles de seguridad

- **Autenticación/Autorización:** MFA en VPN y Bastion; **PAM** con elevación JIT y caducidad; listas de destinos por rol.
- **Protección de sesión (SR 2.6):** cifrado extremo a extremo, **grabación**, time-out, bloqueo de redirecciones, política de clipboard.
- **Monitoreo:** envío de logs a **SIEM**, alertas por intento de acceso fuera de horario o a destinos no permitidos.
- **Postura de endpoint:** verificación previa (EDR/AV, cifrado, parches); denegación si no cumple.

2.3.4 Matriz de acceso por rol

Rol	Origen	Destino permitido	Medio	Controles aplicados
Contratista PLC	VPN → Bastion (N3.5)	Servidor de Ingeniería / HMI (N2) (nunca PLC directo)	RDP / SSH	MFA, PAM (credenciales JIT), ventana horaria, grabación , aprobación por ticket, bloqueo de clipboard
Operador 24x7	VPN → Bastion (N3.5)	HMI / SCADA (N2)	RDP	MFA , grabación, perfiles de solo operación, listas por grupo, alertas fuera de horario
Dirección / BI	VPN → Relay (N3.5)	Portal BI / ERP (N4/N5) (solo lectura de datos)	HTTPS 443	MFA , allowlist de FQDN, token/OAuth, sin salto a OT

2.3.5 Cumplimiento ISA/IEC 62443-3-3

SR 2.1 – Autenticación de usuarios: MFA en VPN/Bastion, PAM y segregación de cuentas.

SR 2.6 – Protección de sesión: cifrado, grabación, expiración y restricciones de redirecciones en RDP/SSH.

SR 3.x – Segmentación y conductos: todo acceso atraviesa DMZ, deny by default en FW-OT/FW-Corp.

2.4 Firewalls y Política de Reglas

2.4.1 FW-OT (L3 ↔ L3.5) y FW-Corp (L3.5 ↔ L4/N5)

FW-OT ubicado entre la red de Operaciones de Sitio (N3) y la DMZ Industrial (N3.5). Su función es aislar la red OT de la DMZ y permitir únicamente las comunicaciones justificadas entre los servicios de supervisión y mantenimiento remoto.

FW-Corp situado entre la DMZ Industrial (N3.5) y el dominio corporativo (N4/N5). Su función es filtrar el tráfico proveniente de IT hacia la zona industrial, garantizando que todas las interacciones se realicen a través de la DMZ.

Detalle completo de reglas, puertos y justificaciones:

Disponible en el archivo complementario [TIF_BalbuenaDante_Tablas.xlsx](#), hoja “Reglas_Firewall”.

2.4.2 Política Global

Default: Deny by default (todo tráfico no documentado es bloqueado).

Inspección: Nivel 7 (capa de aplicación) para detectar protocolos anómalos o túneles ocultos.

Registro: Todos los eventos ALLOW y DENY se envían a Syslog Forwarder → SIEM (N4).

NAT: Solo estático para Relay y Bastion. No se permite NAT dinámico hacia OT.

Auditoría: Cada flujo permitido está documentado y justificado según riesgo y función operativa.

2.5.1 Plan de Direccionamiento y Naming

2.5.2 Plan de Direccionamiento IP por Zona

Zona Purdue	Descripción	Subred /24	Rango de uso interno	Activos principales
N0/N1 – Celdas de Proceso	Equipos de campo y PLCs por etapa	10.10.10.0/24 a 10.10.15.0/24	PLCs: .100–.150	PLC-P1 a PLC-P6 (procesos P1–P6)
N2 – Control y Supervisión	SCADA, HMI, Servidor de Ingeniería, Historiador	10.10.20.0/24	Servidores: .10–.30 / HMI: .200–.220	SCADA (.10), Historiador (.11), Ing. (.30), HMI1–2 (.201–.202)
N3 – Operaciones	Servidor ETL/Reportes y estaciones técnicas	10.10.30.0/24	Servidores: .10–.30	ETL/Reportes (.10), Lab Ops (.20)
N3.5 – DMZ Industrial	Relay de Historian, Bastion, Syslog, Servidor de Archivos	10.10.40.0/24	Servidores: .10–.30	Relay (.10), Bastion (.11), Archivos (.12), Syslog (.13)
N4/N5 – Corporativo y Cloud	ERP, BI, SIEM y Backup en nube	10.10.50.0/24	Servidores: .10–.30	ERP (.10), SIEM (.20), Backup (opcional)

2.5.2 Convención de Nombres (Naming Convention)

Para mantener una estructura uniforme y facilitar la identificación lógica, se adopta el siguiente formato:

<ROL>-<PROCESO>.<ZONA>.<DOMINIO>

Ejemplos:

- PLC-P3.decant.ot.local → PLC del proceso de Decantación (N1)
- SCADA.ctrl.ot.local → Servidor SCADA de control (N2)
- Relay.histdmz.ot.local → Relay de Historiador en la DMZ (N3.5)
- ERP.corp.it.local → Servidor ERP en dominio corporativo (N4/N5)

2.6 Telemetría, Logs y Monitoreo

2.6.1 Arquitectura de Monitoreo

- **Origen de Logs:**
 - **Bastion / Jump Server (N3.5):** registro de sesiones RDP/SSH, autenticaciones MFA, comandos ejecutados y duración de conexión.
 - **Firewalls (FW-OT y FW-Corp):** registros de tráfico permitido/denegado, inspección L7 y eventos de configuración.
 - **Relay, Servidores de Archivos y Syslog (N3.5):** consolidan los logs de la red OT y los reenvían de forma segura.
 - **SCADA y Servidor de Ingeniería (N2):** generación de logs operativos, alarmas y eventos de sistema.
- **Consolidación y Envío:**
Todos los eventos se concentran en el **Syslog Forwarder (10.10.40.13)** dentro de la **DMZ Industrial (N3.5)**. Desde allí, se envían cifrados mediante **Syslog/TLS (puerto 514)** hacia el **SIEM corporativo (10.10.50.20)** ubicado en **N4**.

2.6.2 Política de Retención y Auditoría

- **Retención mínima:** 1 año para logs de seguridad y auditoría (cumplimiento normativo IEC 62443-3-3 SR 6.2).
- **Integridad:** firmas hash diarias y almacenamiento en repositorio protegido contra escritura (WORM).
- **Sincronización horaria:** todos los equipos sincronizados mediante NTP interno (fuente en N4).
- **Revisión periódica:** análisis semanal automatizado de eventos críticos (accesos remotos, cambios en firewall, fallos de autenticación).

2.6.3 Alertas y Correlación de Eventos

El SIEM genera alertas automáticas ante:

- Accesos remotos fuera del horario operativo definido.
- Intentos de conexión directa IT → OT sin pasar por la DMZ.
- Fallos reiterados de autenticación en el Bastion o VPN.
- Modificación no autorizada en configuraciones de firewall o SCADA.

Cada alerta se categoriza por severidad y se notifica al equipo de ciberseguridad y operaciones.

2.7 Justificación Técnica y Trade-offs

2.7.1 Riesgos mitigados:

- **Acceso lateral IT → OT:** Eliminado mediante segmentación Purdue, DMZ industrial (N3.5) y firewalls con política *deny by default*.
- **Exposición directa de PLCs:** Evitada al restringir toda conexión remota a través del *Bastion Jump Server* y VPN controlada.

- **Fugas de información o manipulación de datos:** Protegidas por uso de HTTPS/TLS y autenticación multifactor (MFA).
- **Pérdida de integridad de registros:** Mitigada por la replicación unidireccional del Historian (Data Diode lógico) hacia la DMZ.
- **Fallas de trazabilidad:** Resueltas mediante centralización de logs en Syslog y retención mínima de 1 año en SIEM corporativo.

2.7.2 Controles implementados:

- **Segmentación lógica y física:** Subredes /24 por zona y firewalls dedicados (FW-OT, FW-Corp).
- **Autenticación reforzada:** MFA, PAM y registros de sesión en Bastion.
- **Cifrado extremo a extremo:** TLS/mTLS en conductos críticos (SCADA ↔ Relay, Relay ↔ BI).
- **Principio de mínimo privilegio:** Matriz de accesos por rol y ACLs específicas por host.
- **Monitoreo continuo:** SIEM corporativo con alertas ante comportamientos anómalos.

3. Conclusiones

El diseño de la arquitectura de redes para la planta AquaSur permitió aplicar los principios del modelo Purdue y las buenas prácticas de ciberseguridad industrial. La segmentación por niveles, el control de conductos y el uso de DMZ con acceso remoto seguro refuerzan la protección de los sistemas OT frente a amenazas IT. En conjunto, las medidas propuestas garantizan continuidad operativa, trazabilidad y cumplimiento con los requisitos de la norma ISA/IEC 62443.

4. Referencias

Asociación Internacional de Automatización (ISA). (2020). *Guía rápida: visión general de las normas ISA/IEC 62443*. Recuperado de <https://gca.isa.org/hubfs/ISAGCA%20Quick%20Start%20Guide%20FINAL.pdf>

Instituto Nacional de Estándares y Tecnología (NIST). (2018). *Guía para la seguridad de los sistemas de control industrial (ICS)* (NIST SP 800-82 Rev. 2). Recuperado de <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-82r2.pdf>

Centro para la Seguridad en Internet (CIS). (2021). *Controles de Seguridad Críticos v8*. Recuperado de <https://www.cisecurity.org/controls/v8>

Purdue University. (1990). *Purdue Enterprise Reference Architecture (PERA)*. Recuperado de <https://www.pera.net>

Microsoft Corporation. (2025). *Transformación del acceso remoto seguro en entornos industriales*. Recuperado de <https://www.microsoft.com/insidetrack/blog/transforming-our-vpn-with-global-secure-access-at-microsoft/>

Lucid Software Inc. (s. f.). *Lucidchart: Plataforma de diagramación inteligente*. Recuperado de <https://www.lucidchart.com/pages/es>

Siemens AG. (2022). *Concepto Defense-in-Depth para seguridad industrial*. Recuperado de <https://assets.new.siemens.com/siemens/assets/api/uuid:527cba83-3a7c-4b94-b3a7-19f258013b74/whitepaper-defense-in-depth-es.pdf>

